

Vendor & Third-Party Risk Management Policy

Supply-chain security for tools and service providers (GV.SC)

Document ID: BVT-POL-041

Version: 1.0

Issued: July 02, 2026

Effective Date: _____

Purpose, Scope, and Authority

This policy is part of the BVTech Written Information Security Program, aligned to the NIST Cybersecurity Framework (CSF) 2.0. It applies to all BVTech LLC personnel, contractors, systems, and, where adopted by a client, the client's covered environment. The Managing Partner (or designated security officer) owns this policy, reviews it at least annually, and approves exceptions in writing. Violations may result in disciplinary action up to termination of employment or contract.

Exception process: submit written request describing the business need, compensating controls, and duration. Exceptions expire after 12 months unless renewed. NIST CSF 2.0 references shown per section (GV, ID, PR, DE, RS, RC).

Vendor Tiers and Assessment

Tier	Definition	Assessment Required
Tier 1 — Critical	Access to client systems/data or core service delivery (RMM, backup, EDR, email security, PSA, password manager)	Security review before adoption + annual reassessment; SOC 2 / equivalent attestation where available; breach-notification terms; MFA on our tenant
Tier 2 — Important	Business data but no client-system access (accounting, CRM, communications)	Baseline review; MFA; data-protection terms
Tier 3 — Low	No sensitive data	Basic reputational check

Requirements for Tier 1 Vendors

- Contractual security and confidentiality obligations, and breach notification without undue delay.
- Our tenant hardening: MFA enforced, least-privilege roles, offboarding of staff accounts same-day, API keys inventoried and rotated.
- Concentration risk noted in the risk register; exit/migration path documented (data export capability).
- Vendor incidents affecting our clients trigger the Incident Response Plan and client notification per contract.

Register

A vendor register is maintained listing: vendor, tier, data accessed, admin owners, contract dates, attestations, and last review. Reviewed annually by the security officer.